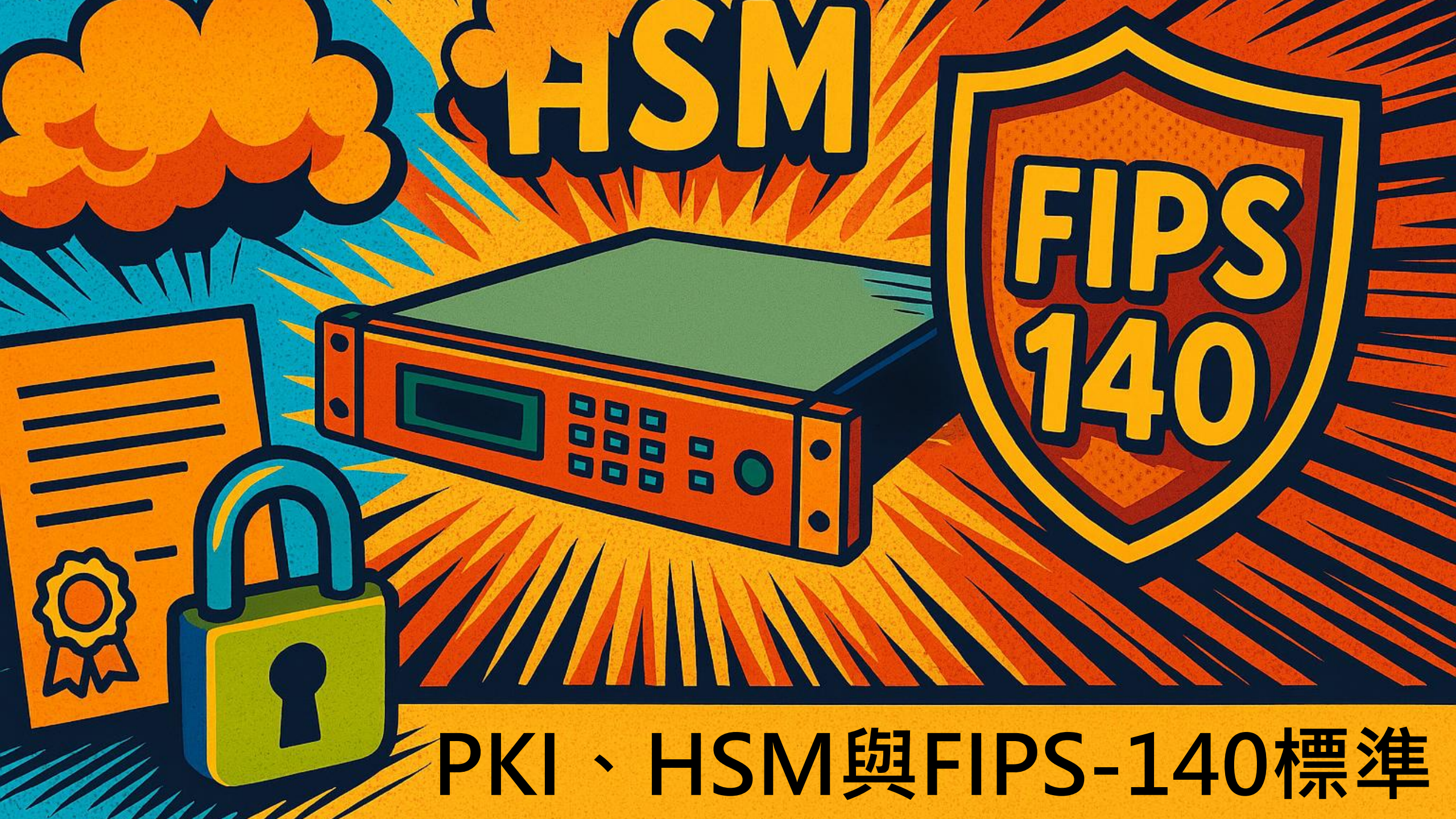




PKI、HSM與FIPS-140標準

大綱

- HSM
- PKI
- FIPS 140



HSM

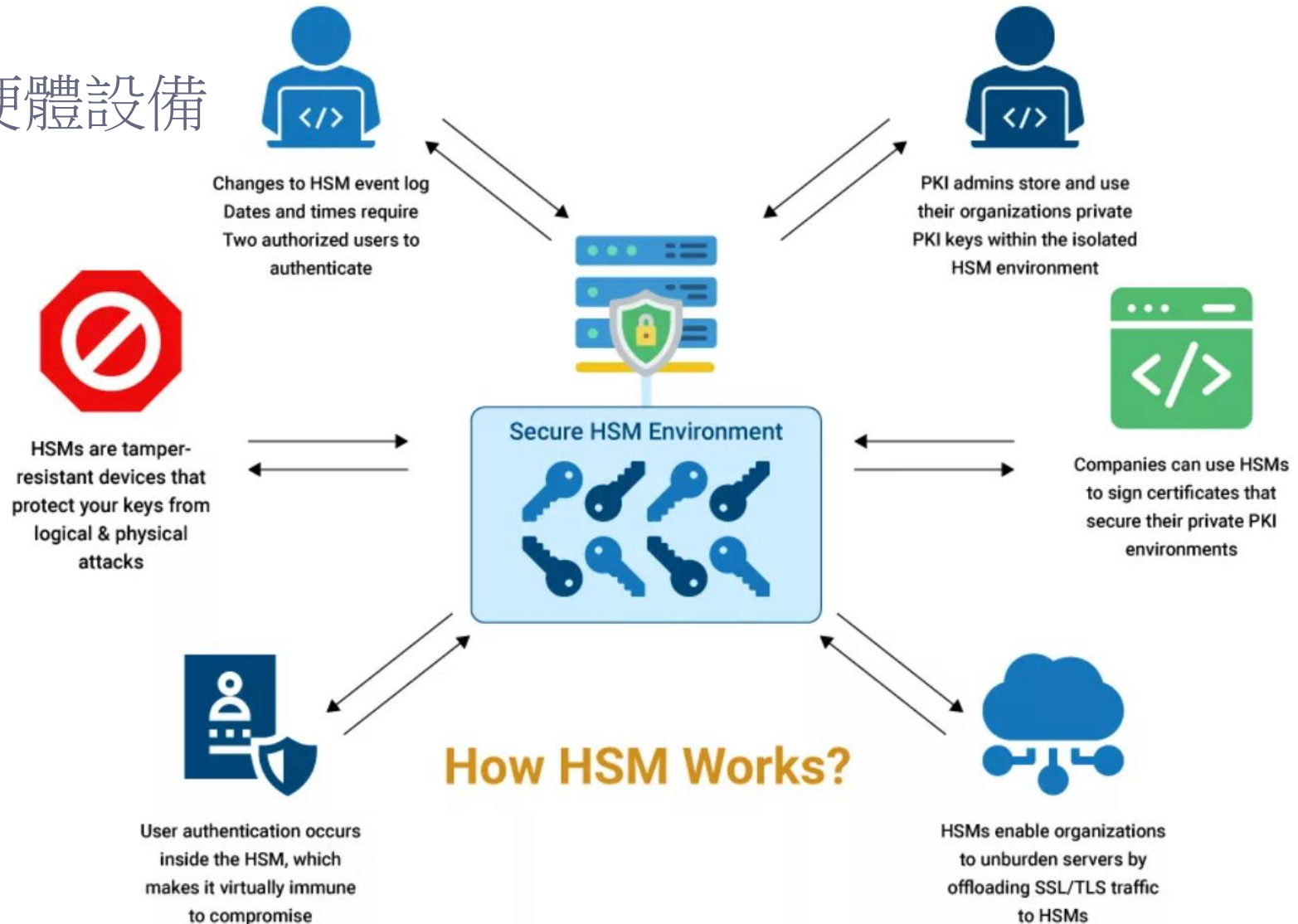
- 硬體安全模組(Hardware Security Module, HSM) 是一種專門用於保護、管理數位密鑰並提供加密演算的物理計算裝置。
- 用來保護及管理密碼編譯金鑰的實體運算裝置

常見應用

- 程式代碼簽署(Code Sign)
- APP簽署
- SSL金鑰管理
- 去識別化(Tokenization)
- 資料庫加密(DB Encryption)
- 時戳服務(Timestamp)
- 憑證簽署(CA)
- OTP金鑰保護
- 點對點加解密應用(End To End Encryption, E2EE)
- 訊息驗證碼運算(Message Authentication Code, MAC)
- 交易驗證碼運算(Transaction Authentication Code, TAC)
- 數位簽章金鑰管理

HSM

- HSM是獨立的防篡改硬體設備



HSM



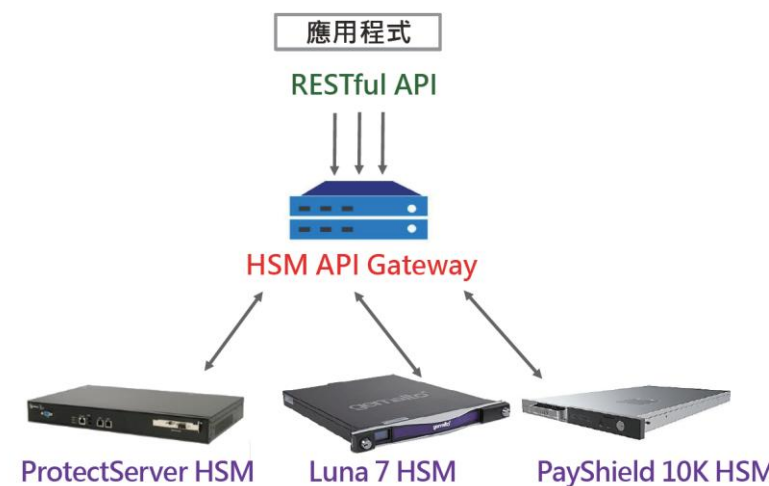
Smart Card HSM



Rack Mounted HSM



USB Token HSM



<https://www.smartcard-hsm.com/opensource.html>

<https://paysecure.com.tw/pages/features/npt7.html>

HSM

- 金融支付專用硬體安全模組

ProHSM™ M10K 【Hardware Security Module】



ProHSM M10K Datasheet

1. ProHSM™ (Hardware Security Module) is a Financial Payment HSM. It provides global and Taiwan payment cryptographic functions.
2. ProHSM™ M10K is the latest product model. It is fully compatible with the functions of the previous series.
3. To fulfill new financial applications, ProHSM™ M10K adds various payment modules (e.g. EMV 4.x, ACS 2.0, ASC TR-31, DUKPT, FISC JWS, etc).
4. For global payment security requirement, ProHSM™ M10K supports AES Key Block LMK in the infrastructure, to enhance the way HSM protects the keys.
5. Support all the Taiwan Switching Center security specifications (e.g. FISC, TCH, NCCC, TWMP, etc)
6. Provide prompt service (including customization), to quickly respond to customer needs.
7. The series of products use hardware cryptographic cards, which comply with the security certificate FIPS 140-2 level 3 or above. All the cryptographic functions fully meet financial regulations.

ProHSM™ KMC 【Key Management Console】

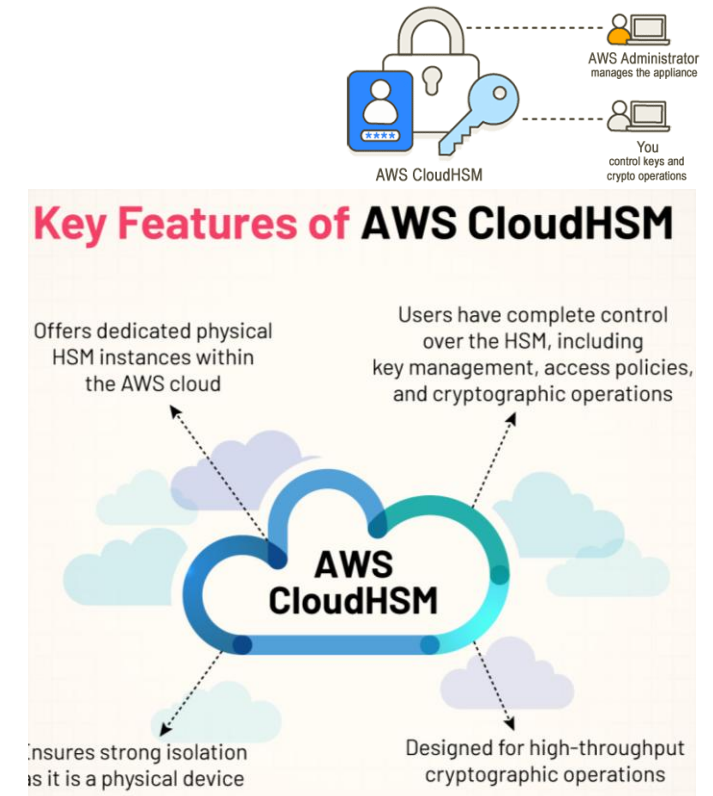
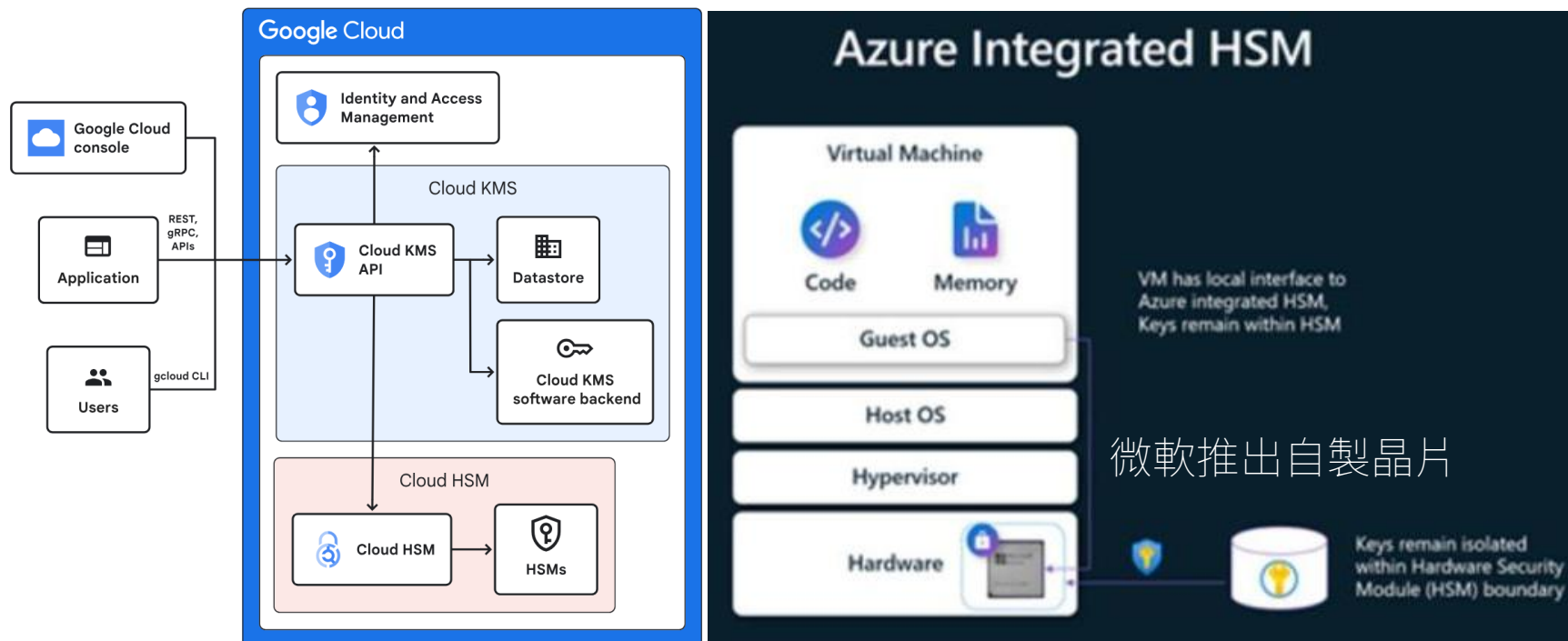


1. ProHSM™ KMC is a key management console for ProHSM™ or other HSMs. It makes key custodians can safely perform key management of HSM.
2. Support impact printer, to meet Taiwan FISC payment requirements.
3. Provide Smartcard Role-Based Access Control (RBAC).
4. Support Secure Channel mechanism to call ProHSM™.
5. ProHSM™ KMC assures to pass the Taiwan FISC financial security auditing.

HSM

- Cloud HSM

- Google, <https://docs.cloud.google.com/kms/docs/hsm?hl=zh-tw#kms-create-key-hsm-console>
- Azure, <https://learn.microsoft.com/zh-tw/azure/dedicated-hsm/overview>
- AWS, <https://aws.amazon.com/tw/cloudhsm/>

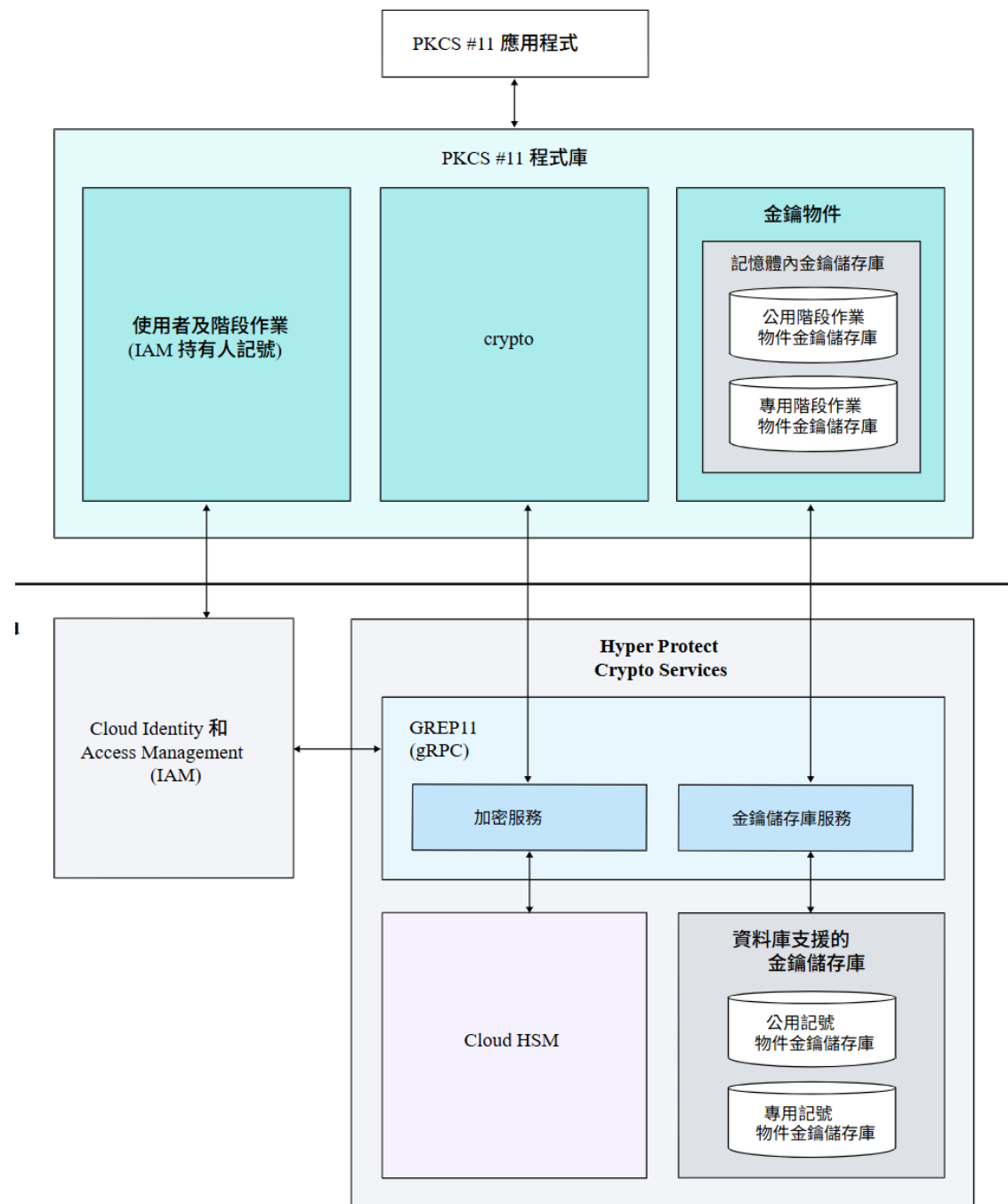


PKCS #11

- PKCS(Public Key Cryptography Standards)是一系列的公開金鑰密碼學標準。這些標準由 RSA 實驗室 (RSA Laboratories) 制定，用於推動公開金鑰密碼學的發展和應用。
 - **PKCS #1: RSA Cryptography Standard**：定義了 RSA 加密和數位簽章的標準。這包括 RSA 公開金鑰加密和簽名的格式，以及相應的數學運算。
 - **PKCS #7: Cryptographic Message Syntax (CMS)**：定義了一種通用的語法，用於表示加密和簽章的資料，包括數位簽章、數位信封 (encrypted message)，以及簽章的格式。
 - **PKCS #8: Private-Key Information Syntax Standard**：定義了私鑰的語法，用於表示和交換私鑰資訊。通常用於將私鑰存儲在檔案中或通過網路進行私鑰的交換。
 - **PKCS #10: Certification Request Syntax Standard**：定義了一種語法，用於向證書授權機構 (Certificate Authority , CA) 提交證書請求。這是用戶向 CA 請求數字憑證的標準格式。
 - **PKCS #11: Cryptographic Token Interface (Cryptoki)**：定義了通用的 API 介面，用於存取硬體安全模塊 (Hardware Security Module , HSM) 和其他加密標記設備。這使應用程式能夠與硬體安全設備進行互動，並利用其安全功能。
 - **PKCS #12: Personal Information Exchange Syntax Standard**：定義了一種語法，用於將密鑰、證書和相關資訊封裝成一個單一的檔案，通常使用 PFX 或 P12 擴展名。這種格式通常用於在應用之間安全地交換私鑰和憑證。

IBM HSM

使用 PKCS #11 API



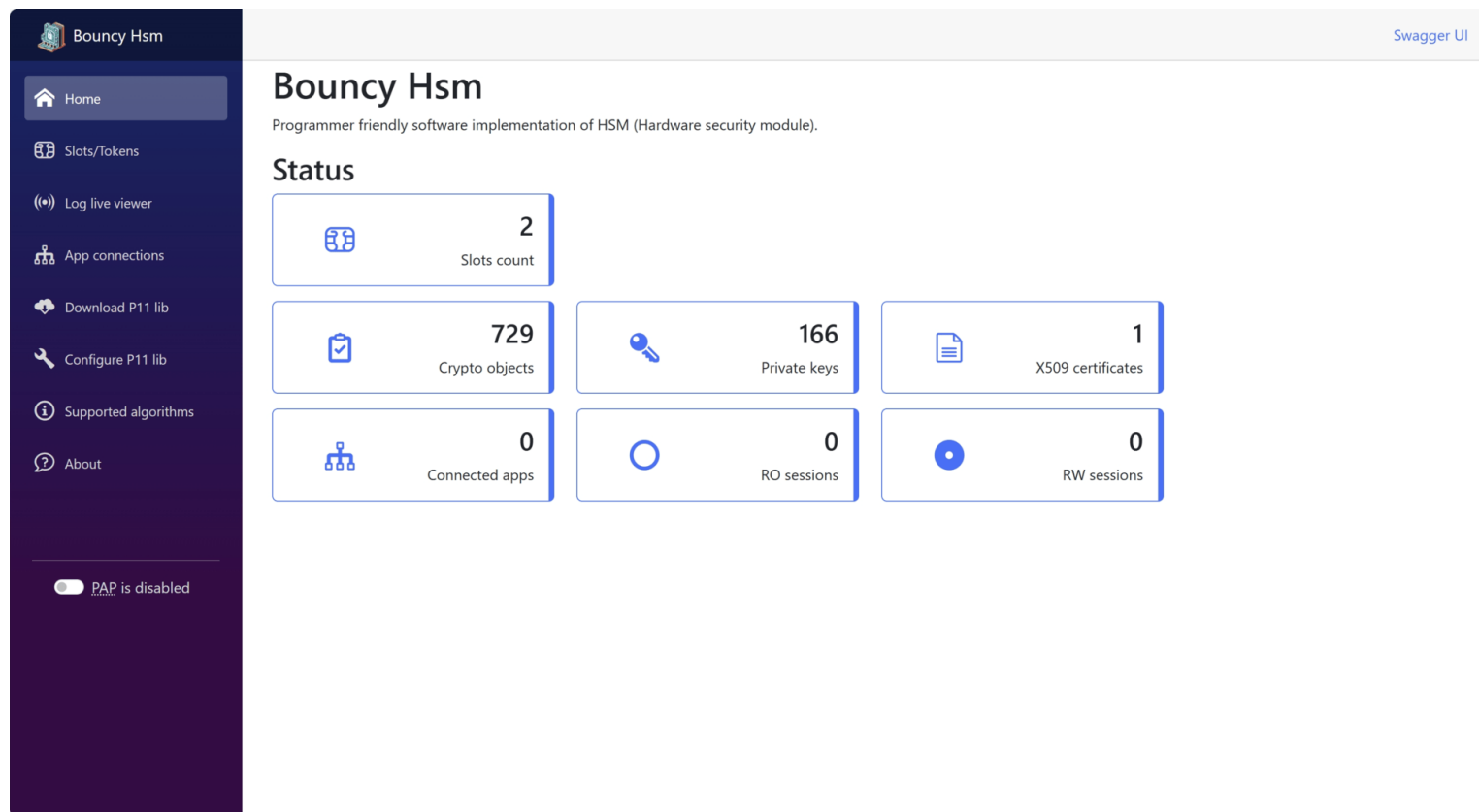
SoftHSM

- 可透過 PKCS#11 介面存取的加密儲存實作。它最初是作為 OpenDNSSEC 專案的一部分開發的。最新版為V2
- 不需要硬體，但也缺乏硬體的安全保護，可做為HSM 模擬及實驗。
 - <https://www.softhsm.org/>
 - <https://github.com/softhsm>



Bouncy Hsm

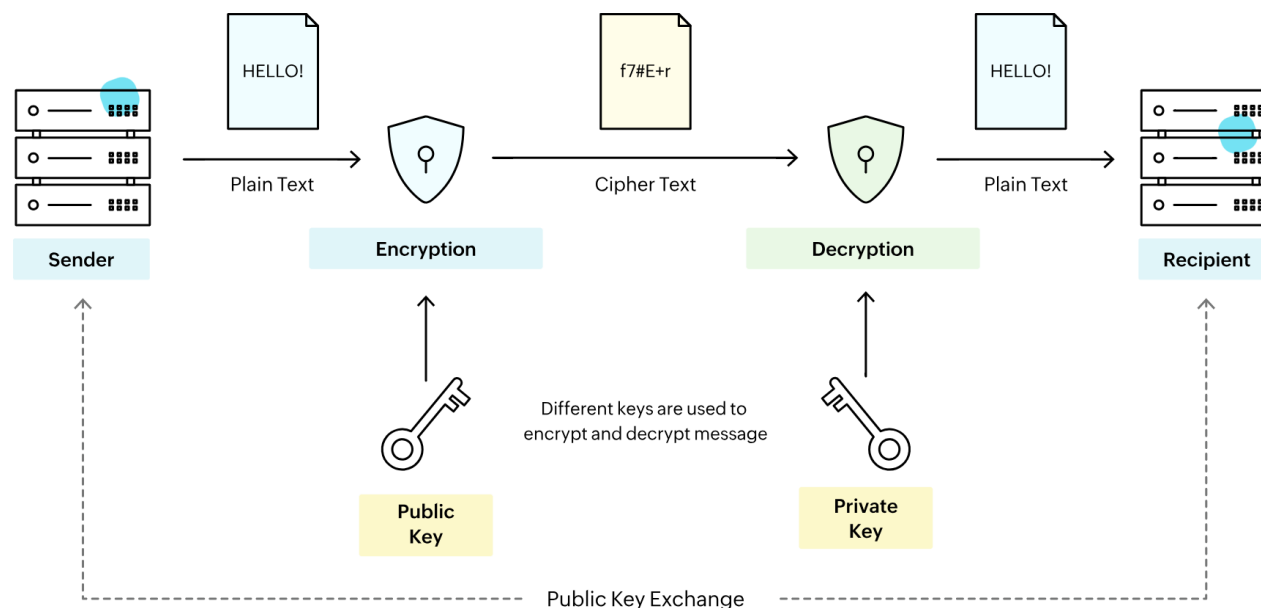
- 模擬 HSM (硬體安全模組) 和智慧卡 (也支援特定區域)
- SoftHSMv2 的替代方案
- Dotnet-based
- <https://github.com/harrison314/BouncyHsm?tab=readme-ov-file>



PKI

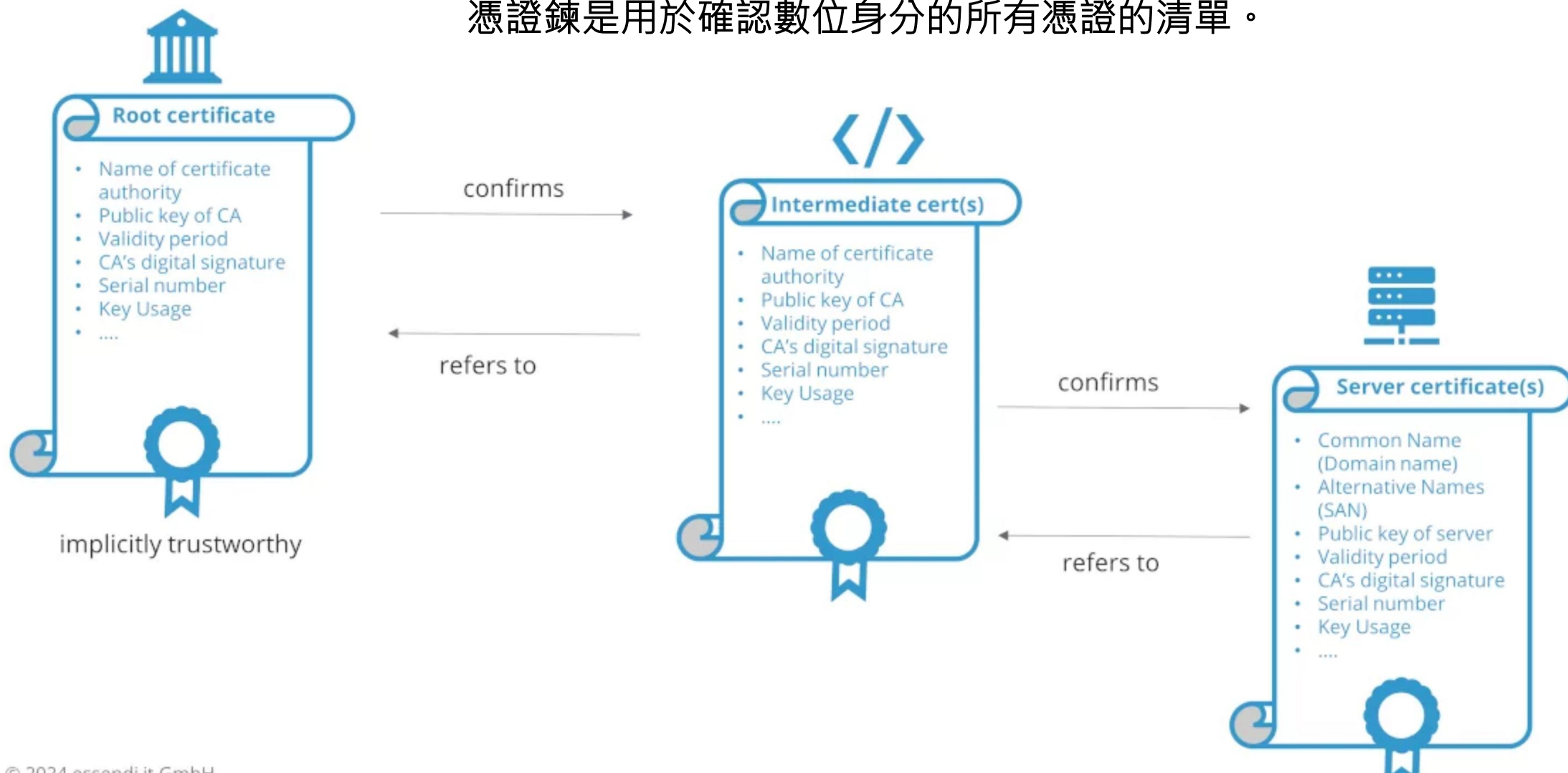
- PKI(Public Key Infrastructure)

- PKI 透過使用公鑰和私鑰的組合進行加密，為資料傳輸創建安全的環境，並確保發送者和接收者之間的信任。
- PKI 透過數位憑證保護資料並建立信任。憑證由憑證授權單位 (CA) 在組織提交憑證簽署請求 (CSR) 後頒發。CSR 獲得批准並頒發證書後，只要證書正確且在有效期內，組織或實體即可對其通訊、網站域名或文件進行身份驗證和保護。



PKI

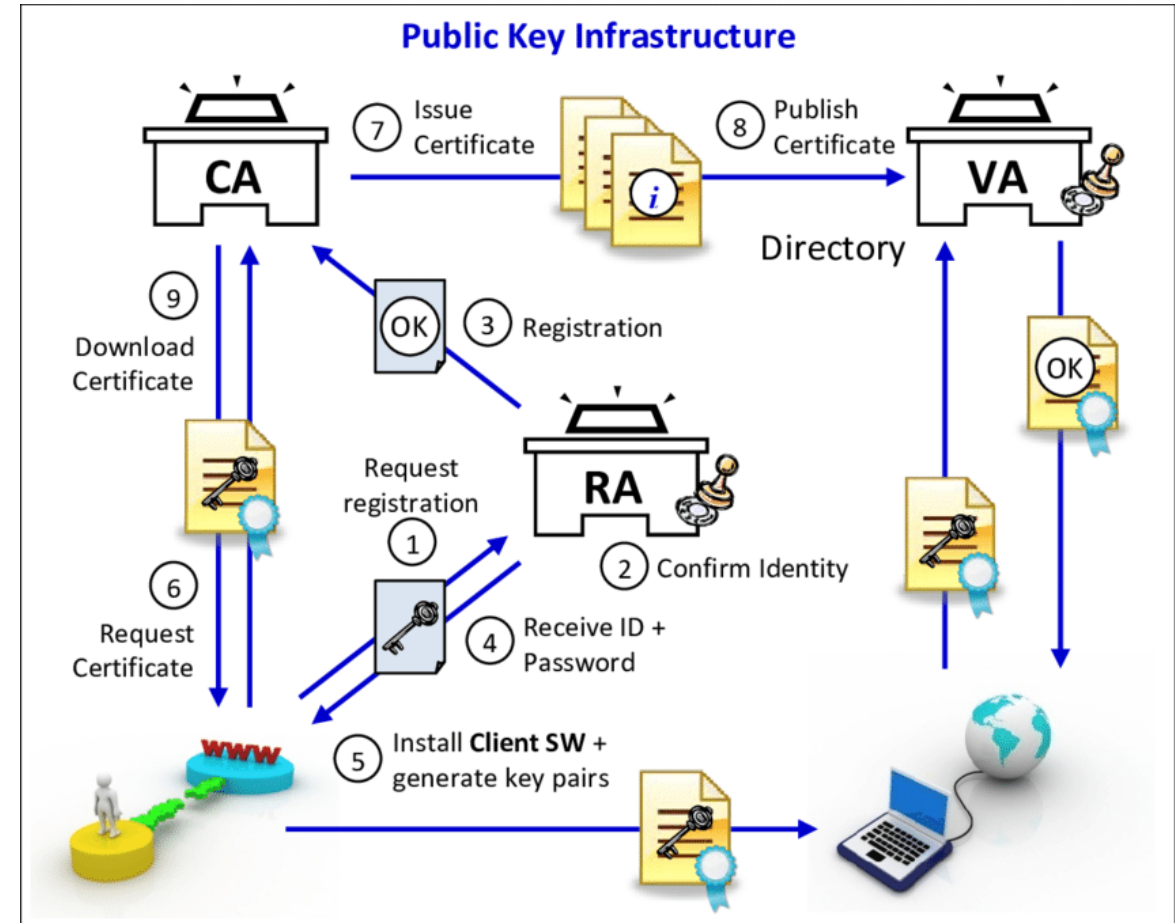
憑證鍊是用於確認數位身分的所有憑證的清單。



PKI

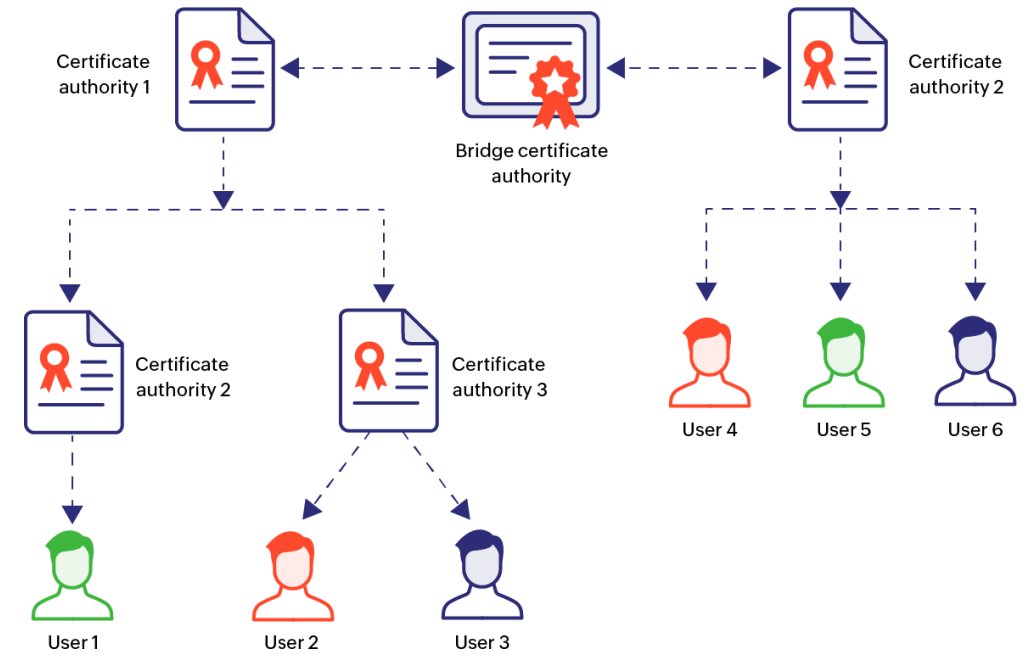
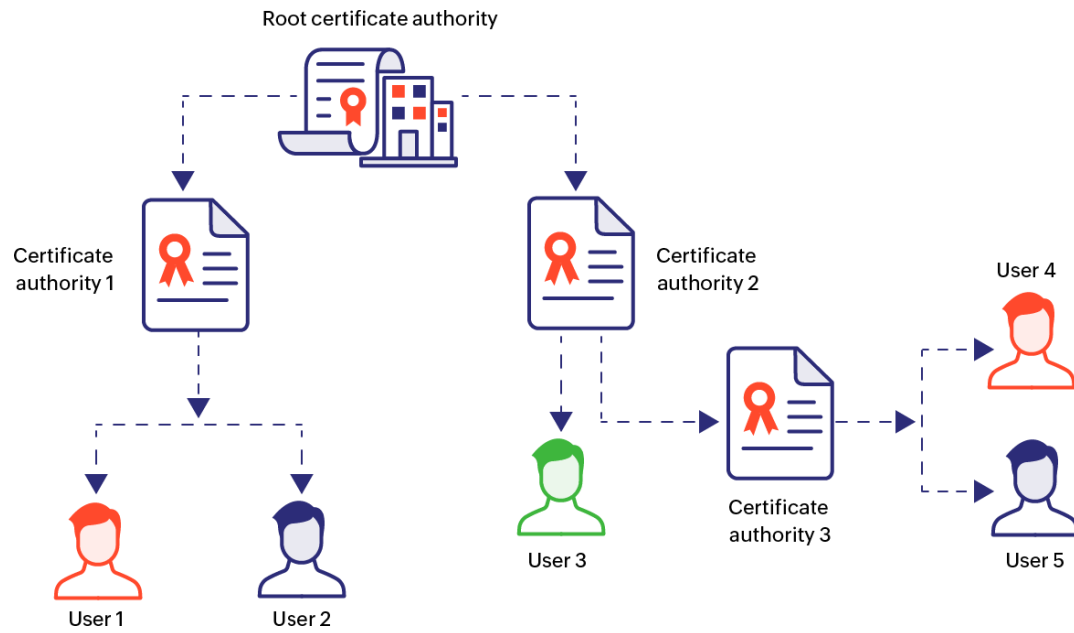
- **PKI重要元件：**

- **Digital Certificate (X.509):** Contains identity + public key
- **Private Key Tokens:** Secure storage for private keys
- **Registration Authority (RA):** Verifies user identity
- **Certification Authority (CA):** Issues and signs certificates
- **Certificate Management System (CMS):** Handles storage and revocation



PKI

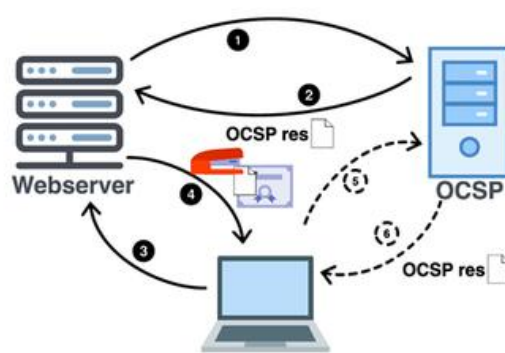
- Root CA & BCA



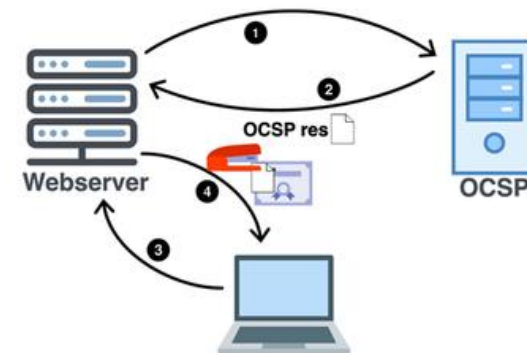
PKI

- **Certificate Management System (CMS)**

- **憑證撤銷清單 (CRL)**：是憑證授權單位 (CA) 在憑證到期日之前撤銷的憑證清單。這通常是由私鑰洩漏等問題引起的。例如，瀏覽器會向頒發憑證的 CA 要求已撤銷的 HTTPS 網頁的憑證列表，CA 隨後會傳回已撤銷和已暫停使用的憑證清單。
- **線上憑證狀態協定 (OCSP)**：線上憑證狀態協定可以提供與憑證撤銷清單 (CRL) 類似的資訊，但請求會發送到 OCSP 伺服器的，這意味著可以更快、更詳細地傳回所需資訊。OCSP 伺服器會詳細說明憑證狀態，包括以下三種回應之一：良好（有效）、已撤銷（暫時或永久撤銷）和未知（伺服器無法辨識）。



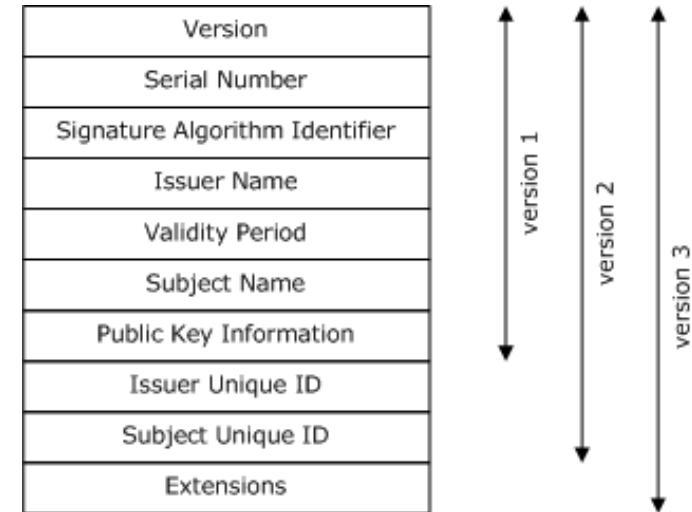
a) OCSP stapling



b) OCSP Must-Staple

X.509憑證

- 國際標準X.509，具有一個特定的結構：
 - **版本 (Version)**：憑證的版本號，通常為1、2或3，指定憑證的格式和屬性。
 - **序列號 (Serial Number)**：由CA分配的唯一序列號，用於識別每個憑證的唯一性。
 - **簽發者 (Issuer)**：CA的名稱和數位簽名，用於確保憑證的真實性。
 - **主體 (Subject)**：數據擁有者的名稱和其他識別信息，指定了該憑證的用戶。
 - **有效期 (Validity Period)**：憑證的有效期限，包括開始日期和結束日期。
 - **公開金鑰 (Public Key)**：數據擁有者的公開金鑰，用於加密和數位簽名驗證。
 - **數位簽名 (Digital Signature)**：CA對整個憑證的數據進行的數位簽名，用於確保憑證的完整性和真實性。
- 最常見的兩種方式是DER (Distinguished Encoding Rules) 和PEM (Privacy-Enhanced Mail) 編碼方式



其他相關

- PKCS (Public Key Cryptography Standards)
- X.509 簽章或加密資料的格式標準
- 美國聯邦密碼模組安全標準FIPS 140-3
 - **Cryptographic Module Validation Program(CMVP)**
 - <https://csrc.nist.gov/projects/cryptographic-module-validation-program>

- .pem – 隱私增強型電子郵件格式，通常是Base64格式的。
- .cer, .crt, .der – 通常是DER二進制格式的。
- .p7b, .p7c – PKCS#7 SignedData structure without data, just certificate(s) or CRL(s)
- .p12 – PKCS#12格式，包含憑證的同時可能還包含私鑰
- .pfx – PFX，PKCS#12之前的格式（通常用PKCS#12格式，比如由網際網路資訊服務產生的PFX檔案）

FIPS 140

- FIPS 140 是美國國家標準與技術局 (NIST) 制定的一系列聯邦資訊處理標準，用於驗證加密模組（軟體、硬體或韌體）的安全性
- 最新的標準為：**FIPS 140-3**
- 與 **ISO/IEC 19790** 接軌
- 核心：
 - **認證單位**：由 NIST 與加拿大網路安全中心 (CCCS) 共同推動的「密碼模組驗證計畫」(CMVP) 進行驗證。
 - **應用領域**：美國聯邦政府、承包商及其供應商，適用於加密模組的設計與實作。
 - **安全等級**：定義了 1 到 4 個安全等級，等級越高，物理安全防護（如防篡改）和安全性越強。

FIPS 140-3

- **FIPS 140-3 認證計劃與相關要求**

- 密碼演算法認證計畫 (Cryptographic Algorithm Validation Program, CAVP)

- 提供對已核准(即FIPS核准和NIST推薦)密碼演算法及其各個組成部分的驗證測試。密碼演算法驗證是密碼模組驗證的先決條件，開發廠商需向認可實驗室提出演算法驗證測試申請，經過認可實驗室成功測試後便會公告在NIST官方頁面，說明開發廠商、實作方式、操作環境、驗證日期及演算法詳細資訊。

- 密碼模組認證計畫 (Cryptographic Module Validation Program, CMVP)

- 提供密碼模組驗證及測試，其先決條件為模組內使用了至少一個通過CAVP密碼演算法驗證之FIPS核准或NIST推薦的密碼演算法。根據密碼演算法的使用定義出相關模組邊界(Boundary)，認可實驗室對其邊界內相關硬體、軟體、韌體、系統及介面等元件，根據衍生測試要求(Derived Test Requirements, DTR)進行測試和驗證。驗證之測試結果由認可實驗室交由NIST進行審核，通過驗證之密碼模組同樣也會被公告在NIST官方頁面，說明開發廠商、實作方式、操作環境、驗證日期及演算法證書編號等資訊。

FIPS 140-3

- FIPS 140-3密碼模組認證計畫中的安全要求包含下列11個安全領域：
 1. Cryptographic Module Specification (密碼模組規格)
 2. Cryptographic Module Interfaces (模組資料介面)
 3. Roles, Services, and Authentication (授權的角色、服務和身份驗證)
 4. Software/Firmware Security (軟體/韌體安全)
 5. Operational Environment (作業系統安全)
 6. Physical Security (實體安全)
 7. Non-invasive Security (非侵入式安全)
 8. Sensitive Security Parameter Management (敏感安全參數管理)
 9. Self-Tests (自我測試)
 10. Life-cycle Assurance (生命週期保證)
 11. Mitigation of Other Attacks (抵擋其他攻擊方法)

FIPS 140-3

- **安全等級1**

- 模組至少使用一個NIST規定或建議的安全功能(Security Function)。
- 執行在無法改動(Non-modifiable)、限制改動(Limited-modifiable)或可改動(Modifiable)的操作環境中。
- 實體安全僅要求使用一般生產等級之組件。
- 以文件說明所有非侵入式或其他攻擊的減緩機制。

- **安全等級2**

- 實體安全增加竄改證據(Tamper-evidence)機制的要求，其中包含使用防竄改塗層或防撬鎖。
- 使用基於角色(Role-based)使用者驗證機制。
- 軟體模組運行在可改動之操作環境，需要提供存取控制清單(Access Control List, ACL)以控管保護避免非授權執行、修改、洩露及讀取軟體模組。

FIPS 140-3

• 安全等級3

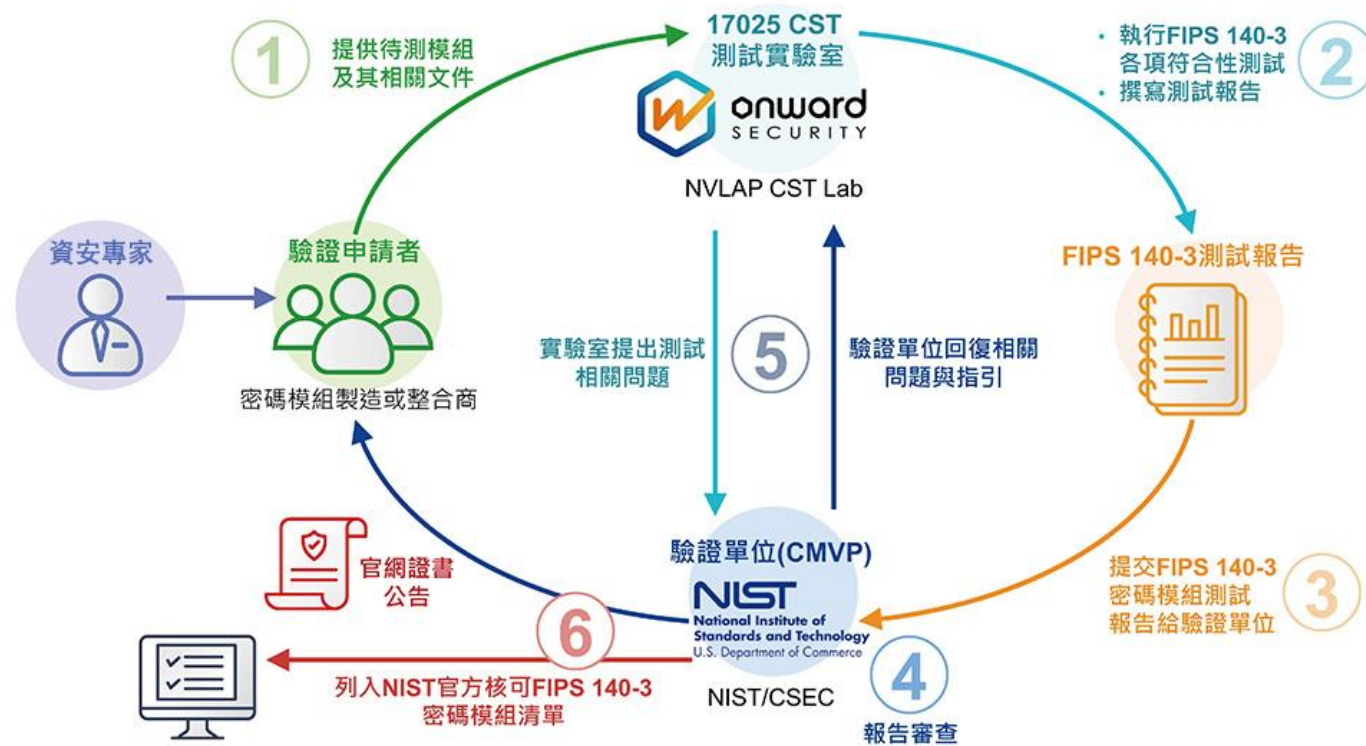
- 新增避免非授權存取於模組內部敏感安全參數之要求。
- 實體安全新增防竄改回應機制，和避免由通風洞口進行探測攻擊之安全機制等要求。
- 使用基於身份(Identity-based)使用者驗證機制。
- 需使用信任路徑(Trust Path)或分持機密(Split Knowledge)的方式在手動建立明文的關鍵安全參數時進行加密。
- 新增針對操作環境中模組工作電壓與溫度範圍的保護機制，避免超出工作環境能力而導致安全性疑慮的要求。
- 所有非侵入式攻擊的減緩機制，需根據標準規範之安全等級3測試要求進行測試。
- 新增生命週期保證(Life-cycle Assurance)要求包括:自動化設置管理、詳細設計、Low-level測試和使用廠商(Vendor)提供之資訊進行操作驗證。

• 安全等級4

- 使用多因子(Multi-factor)使用者驗證機制。
- 所有非侵入式攻擊的減緩功能，需根據標準規範之安全等級4測試要求進行測試。

FIPS 140-3

- 經由受認可的CST測試實驗室進行加密模組測試，產出驗證報告，再由NIST審核通過後，證書將發布到NIST官網上提供搜尋。



FIPS 140-3

- **Security Requirements for Cryptographic Modules**
 - <https://csrc.nist.gov/pubs/fips/140-3/final>
- **Cryptographic Module Validation Program (CMVP)**
 - <https://csrc.nist.gov/projects/cryptographic-module-validation-program>
 - **Search**驗證清單
 - <https://csrc.nist.gov/Projects/cryptographic-module-validation-program/validated-modules/search>
- **SP 800-140 Series Supplemental Information**
 - <https://csrc.nist.gov/Projects/cryptographic-module-validation-program/sp-800-140-series-supplemental-information>
 - SP 800-140 FIPS 140-3 Derived Test Requirements (DTR)
 - SP 800-140A CMVP Documentation Requirements modifies
 - SP 800-140Br1 CMVP Security Policy Requirements
 - SP 800-140Cr2 CMVP-Approved Security Functions
 - SP 800-140Dr2 CMVP-Approved Sensitive Security Parameter Generation and Establishment Methods modifies
 - SP 800-140E CMVP-Approved Authentication Mechanisms
 - SP 800-140F CMVP-Approved Non-Invasive Attack Mitigation Test Metrics